

COSTAR

- **Contexto:** Evaluar la gobernanza de ciberseguridad del proyecto de detección de incidentes viales con replanificación dinámica de rutas mediante NIST CSF 2.0
- **Objetivo:** Evaluar la consistencia de la gobernanza de riesgo de ciberseguridad del proyecto frente a las seis categorías de GOVERN.
- **Style:** Ejecutivo, basado en el contexto y en los documentos provicionados.
- **Tone:** Neutral y profesional.
- **Audiencia:** Asesor del proyecto, stakeholders y docente de clase de ciberseguridad.
- **Response:** Resumen de Govern, evaluación por categorías con estado.

Caso de uso 1.

Categoría GV	Estado	Evidencia
GV.OC (Contexto organizacional)	Parcial	Se identifican 3 actores (Investigador, Agente Autónomo, Infraestructura); luego se delimita el alcance a simulación pura. Falta declarar explícitamente a quién afectaría un fallo en un eventual despliegue real.
GV.RM (Estrategia de gestión de riesgo)	Alineado (parcialmente)	RNF-02 fija tolerancia cuantitativa (falsas alarmas $\leq 10\%$); tratando los errores de detección bajo el marco conceptual de ISO 21448 como limitación de desempeño. Falta un plan de acción formal para cuando el umbral se incumple (se incumplió: 30.6%).
GV.RR (Roles, responsabilidades, autoridades)	Parcial	Los ADRs documentan decisiones con alternativas consideradas; el asesor funciona como autoridad de aprobación metodológica. No hay declaración explícita de quién tiene autoridad para aceptar un riesgo de seguridad residual.
GV.PO (Política)	Parcial	Tabla IV declara qué estándares aplican y con qué alcance. No hay una política de seguridad independiente que gobierne decisiones futuras (ej. "todo cambio de flujo de datos exige actualizar la Tabla XV").
GV.OV (Supervisión)	Parcial	Existe revisión iterativa del documento completo con el asesor. No hay un mecanismo de supervisión específico de seguridad.
GV.SC (Cadena de suministro)	No abordado	Sin tratamiento de la procedencia del dataset ACCIDENT, del

		backbone ResNet50 preentrenado (arquitectura Arq-D: ResNet50+CBAM+ConvLSTM2D), ni de dependencias de software (CARLA, ONNX Runtime).
--	--	--

Rupturas de gobernanza:

- **Política vs. estrategia:** la estrategia de riesgo (RNF-02) es más fuerte que la política que la respalda puesto que hay un número objetivo, pero no un procedimiento escrito de qué hacer cuando se incumple.
- **Apetito de riesgo:** se declara el incumplimiento del 30.6% en vez de ocultarlo.
- **Rendición de cuentas:** la autora y el asesor son los encargados de manera implícita, pero no se formaliza para decisiones de seguridad específicas
- **Supervisión:** genérica, no orientada a seguridad.
- **Cadena de suministro:** ausente

Implicaciones de riesgo de gobernanza:

- **Autoridad de decisión:** aceptar A-10 (no autenticación) como riesgo residual debería ser una decisión trazable del asesor, no una frase en el texto.
- **Exposición regulatoria:** el alcance se restringe explícitamente a simulación (Sección 1.6), lo cual es en sí mismo un control de gobernanza correcto.
- **Supervisión:** al no ser específica de seguridad, un cambio futuro en un flujo de datos podría pasar desapercibido para el modelo de amenazas.
- **Aceptación de riesgo:** el patrón "se acepta como riesgo residual" aparece más de una vez en la Tabla XV (A-10, en menor medida A-01/A-05) sin una única instancia formal que las agrupe.

SSDF

- El SSDF dice como se construye el sistema con menos vulnerabilidades. Conectándolo directamente con los vacíos de Govern.

SSDF	Vacio de GV	Recomendacion	Tipo de control
PO.1 (requisitos de seguridad tempranos)	GV.PO	Formalizar la Tabla XV como "definition of done" de seguridad en cada iteración Crystal Clear, no solo un paso de diseño inicial	Organizacional
PS.2 (procedencia de artefactos)	GV.SC	Versionar cada .h5 con hash de commit y partición de datos; registrar procedencia/licencia del dataset	Tecnológico

		ACCIDENT y del backbone	
PW.7/PW.8 (revisión y prueba)	GV.RR (autoridad implícita sin verificación)	Prueba de regresión para A-07 (conurrencia); revisión de código como parte del checklist, no solo documentación	Tecnológico
RV.1 (identificación continua de vulnerabilidades)	GV.OV	Revisar la Tabla XV cada vez que se modifica un flujo de datos, no una sola vez al final	Organizacional
RV.2/RV.3 (gestión y causa raíz)	GV.RM (plan de acción cuando se incumple el umbral)	Documentar plan de remediación con responsable y fecha para A-06 y A-07	Organizacional
PW.4 (reutilización de componentes seguros)	Producto, sin vacío GV directo pero cierra superficie de ataque	pip-audit/npm audit en el flujo de construcción	Tecnológico

Uso de la IA

Se hizo uso de la IA como se decía en el ejercicio, donde se desarrolló COSTAR de forma autónoma, usando IA generativa como un apoyo para identificar la gobernanza del proyecto y como este se relaciona con SSDF.